API "Lấy kết nối" — PM khách tự lấy chuỗi kết nối mới từ Trung tâm thông báo

Dự án: *TTTBSixOs (Trung tâm thông báo) · nhánh* `namnhat_1808_TTTB_TrungTamThongBao`
Ngày: *29/10/2026 ·* ***Trạng thái:*** *đã chốt thiết kế, chờ code*
Mọi giá trị trong tài liệu (mã, mật khẩu, máy chủ) đều là ví dụ giả.

1. Mục tiêu

Khi database của một khách **đổi máy chủ, đổi tài khoản hoặc đổi mật khẩu**, người vận hành chỉ sửa **một chỗ** ở Trung tâm

thông báo (TTTB). Lần khởi động sau, phần mềm (PM) của khách **không vào được DB cũ sẽ tự hỏi TTTB**, nhận chuỗi kết nối mới,

tự ghi lại file `appsettings.json` rồi chạy tiếp — không phải đi sửa tay từng nơi.

2. Giới hạn đã chốt

#	Giới hạn	Hệ quả thiết kế
1	PM chỉ có: **địa chỉ API TTTB + MaCSKCB + chuỗi kết nối cũ** trong appsettings	Không thêm khoá vào appsettings, không viết cứng khoá trong code, không dùng biến môi trường
2	Lúc PM gọi API thì **DB của nó đã chết**	Không đọc được gì từ DB khách — bí mật duy nhất còn lại là chuỗi kết nối cũ
3	TTTB **chỉ giữ 1 cột** `ConnectionString` cho mỗi đối tác	Thêm 1 cột khoá 32 byte tự quản (`KhoaBatTay`), không thêm cột chuỗi thứ hai
4	MaCSKCB là mã công khai, và **không duy nhất** (00001…00005 mỗi mã 2–3 dòng)	Mã chỉ để lọc, không dùng để xác thực

3. Vì sao không dùng riêng mật khẩu làm khoá

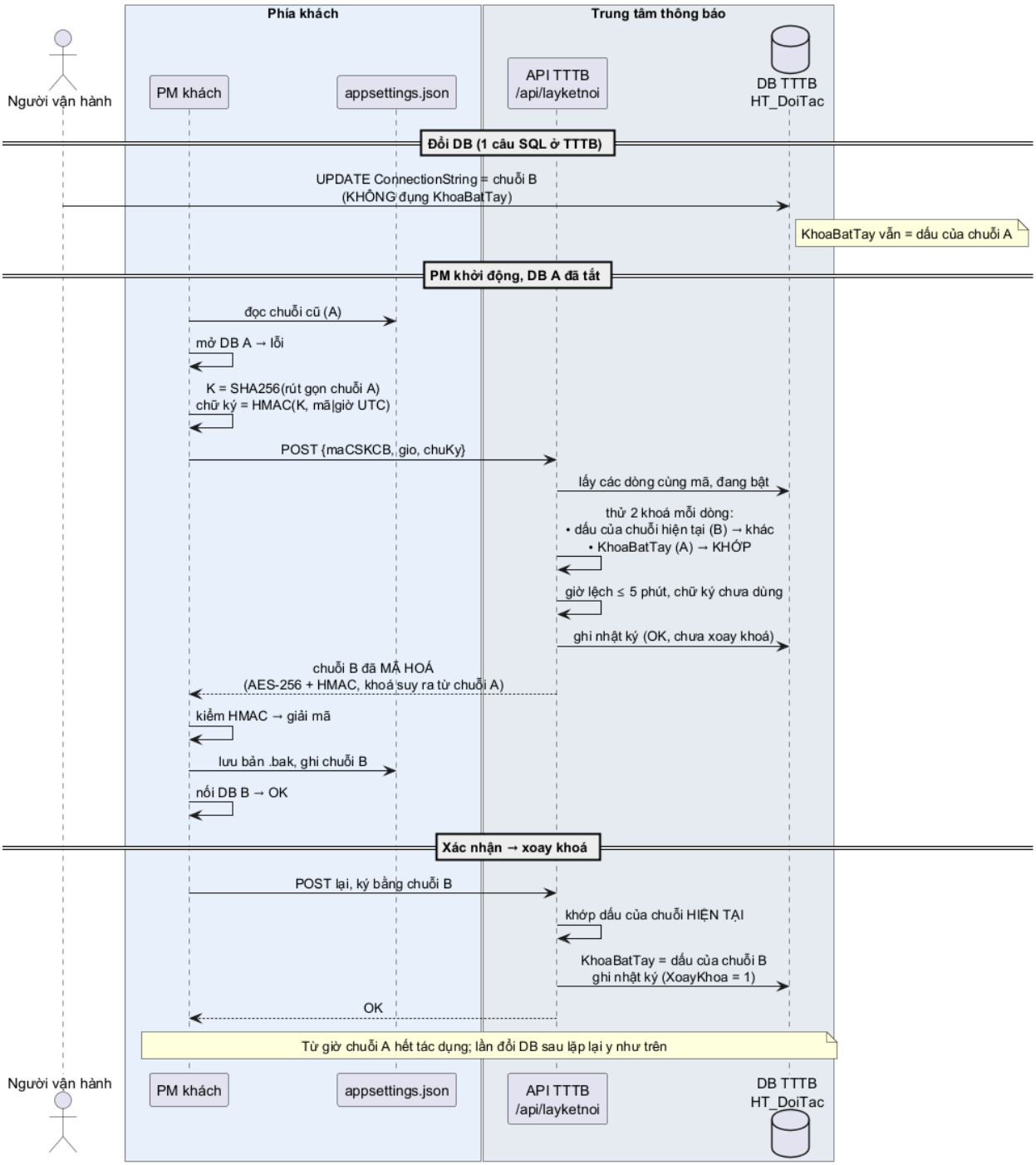
Đo trên DB `Chinh_TTTBSixOs` ngày 29/10/2026 (chỉ đếm, không đọc mật khẩu ra):

Đo	Kết quả
Đối tác có chuỗi kết nối	48
Số mật khẩu khác nhau	**1** — cả 48 dùng chung
Số tài khoản / máy chủ khác nhau	1 / 1
Thứ duy nhất khác nhau	**tên database**

⇒ Khoá bắt tay là **dấu vân tay của cả chuỗi kết nối** đã rút gọn về 4 phần `máy chủ | database | tài khoản | mật khẩu`

(bỏ các tuỳ chọn phụ như `Encrypt`, `TrustServerCertificate` để chuỗi bên khách và bên TTTB lệch hình thức vẫn khớp).

4. Luồng chính — đổi DB của khách từ máy chủ A sang B



Vì sao chưa xoay khoá ngay khi trả chuỗi B: TTTB không biết PM đã ghi được file hay chưa. Nếu ghi lỗi, khoá cũ vẫn còn nên

lần sau PM thử lại được. Chỉ khi PM ký được bằng chuỗi **mới** (bước xác nhận) mới chứng minh nó đã cầm chuỗi mới.

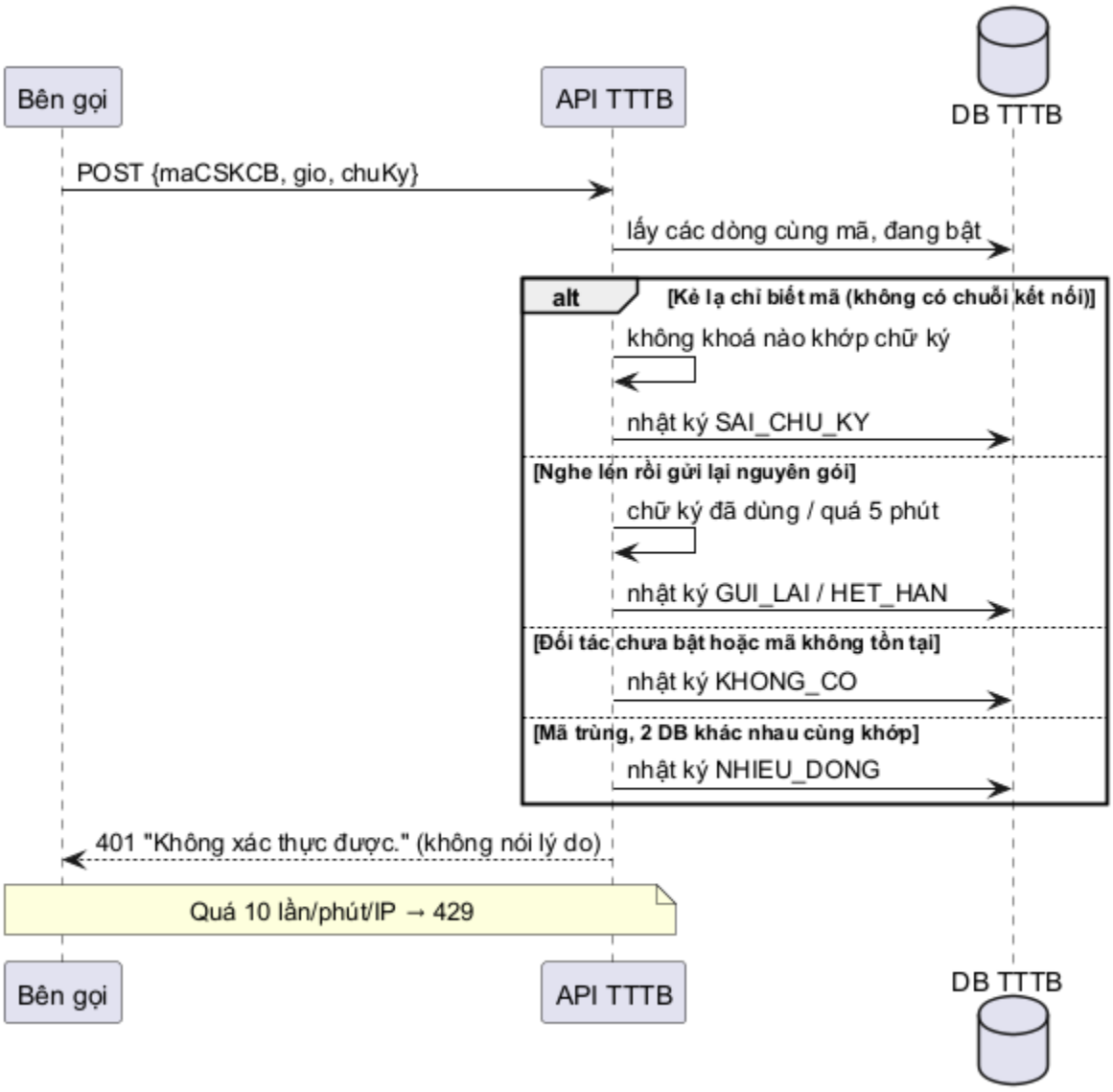
5. Trạng thái qua từng mốc

Mốc	ConnectionString (TTTB)	KhoaBatTay (TTTB)	appsettings PM

0. Trước khi đổi	A	dấu A	A
1. Admin UPDATE	**B**	dấu A (không đụng)	A — PM chết
2. PM xin chuỗi	B	dấu A (giữ)	A
3. PM ghi file	B	dấu A	**B**
4. PM xác nhận	B	**dấu B** (xoay)	B
5. Đổi lần sau B → C	**C**	dấu B	B — lặp lại từ mốc 2

> 🔴 ***Luật vận hành:*** *chỉ đổi DB lần tiếp theo khi đã thấy dòng* `XoayKhoa = 1` *của khách đó trong nhật ký.*
> *Đổi B → C khi PM chưa xác nhận thì PM đang cầm B, còn TTTB chỉ còn dấu A và C ⇒ PM bị khoá ngoài, phải đặt lại khoá ở màn Admin.*

6. Các trường hợp bị từ chối



Tình huống	Kết quả	Vì sao an toàn
Kẻ lạ chỉ biết MaCSKCB	❌ 401	Không có chuỗi kết nối thì không ký được
Nghe lén, gửi lại gói cũ	❌ 401	Chữ ký dùng 1 lần + sống 5 phút; bản

		mã không đọc được nếu không có chuỗi cũ
Mã trùng (00001 gắn nhiều dòng)	✅ trả đúng dòng	Chỉ dòng có đúng tên DB mới khớp
Sửa 1 byte bản mã trên đường truyền	❌ PM từ chối	HMAC sai ⇒ không giải mã, không ghi file

7. Thay đổi ở TTTB

Hạng mục	Nội dung
`HT_DoiTac.KhoaBatTay varbinary(32)`	Dấu vân tay chuỗi PM đang cầm. TTTB **tự điền** lúc khởi động, **tự xoay** khi PM xác nhận
`HT_DoiTac.ChoPhepLayKetNoi bit`	Mặc định tắt, bật từng đối tác
Bảng `HT_NhatKyLayKetNoi`	Giờ, IP, mã, đối tác, kết quả, có xoay khoá không. Không lưu chuỗi/mật khẩu
`POST /api/layketnoi`	Endpoint PM gọi (không cần đăng nhập, giới hạn 10 lần/phút/IP)
Màn Admin **"Khoá lấy kết nối"** (menu Hệ thống)	Bật/tắt từng đối tác, xem trạng thái khoá + lần gọi gần nhất, nhật ký; **"Đặt khoá"**: dán chuỗi trong appsettings của khách ⇒ TTTB băm và lưu. Khoá không bao giờ hiện ra màn hình
Cột mới **không** khai báo vào entity EF	Deploy trước hay chạy SQL trước đều không làm vỡ các màn đang có

Vận hành khi chuyển DB cho khách — 1 câu SQL:

```
UPDATE HT_DoiTac
   SET ConnectionString = N'Server=B;Database=PKDK_TN;User Id=...;Password=...',
       ChoPhepLayKetNoi = 1          -- KHONG dung toi KhoaBatTay
 WHERE Id = 20048;
```

8. Phía PM khách

- TTTB giao kèm **1 file C# mẫu** (`LayKetNoiTuTTTB.cs`): rút gọn chuỗi, ký, gọi API, kiểm + giải mã, ghi appsettings (có `.bak`), gọi xác nhận.
- Địa chỉ TTTB: đọc trong DB khi còn sống; DB chết thì lấy `TTTB:DiaChi` trong appsettings.
- Kèm **bộ Postman đóng vai PM khách** để đồng nghiệp test: chỉ cần dán chuỗi cũ/mới, script tự ký và tự giải mã.

9. Phương án đã cân nhắc và bỏ

Phương án	Vì sao bỏ
Khoá AES chung viết cứng trong code	Dịch ngược 1 bản cài là lộ khoá của cả 48 khách
API trả key theo MaCSKCB, PM tự nối DB TTTB	Mã công khai ⇒ ai cũng lấy được key; DB TTTB chứa chuỗi kết nối của **mọi** khách
Chỉ dùng mật khẩu DB làm khoá	48/48 đối tác chung 1 mật khẩu ⇒ không phân biệt được ai với ai
Thêm cột `ConnectionStringCu`	Sếp chỉ giữ 1 cột chuỗi kết nối ⇒ thay bằng `KhoaBatTay` 32 byte
Lưu khoá trong DB của khách	Lúc cần khoá thì DB khách đã chết

10. Lưu ý bảo mật cần sếp biết

🔴 ***48 DB khách đang dùng chung 1 tài khoản + 1 mật khẩu trên cùng 1 máy chủ.*** *Ai có appsettings của một khách thì đã vào*
được DB của mọi khách — API mới không làm việc này tệ hơn, nhưng đây là rủi ro lớn nhất hiện có. Đề xuất (việc riêng, ngoài task):
mỗi khách một tài khoản SQL riêng chỉ có quyền trên DB của mình.